Domain 2: Security and Compliance

Task Statement 2.1: Understand the AWS shared responsibility model.

Knowledge of: • AWS shared responsibility model

Skills in: • Recognizing the components of the AWS shared responsibility model • Describing the customer's responsibilities on AWS • Describing AWS responsibilities • Describing responsibilities that the customer and AWS share • Describing how AWS responsibilities and customer responsibilities can shift, depending on the service used (for example, Amazon RDS, AWS Lambda, Amazon EC2)

Summary Notes: AWS Shared Responsibility Model

🔄 What is the AWS Shared Responsibility Model?

The AWS Shared Responsibility Model defines **who is responsible for security and compliance** in the cloud:

> **AWS is responsible for security *OF* the cloud**
> **Customers are responsible for security *IN* the cloud**

Think of it as **shared but clearly divided responsibilities**.

🧱 Two Main Responsibility Areas

☁️ AWS Responsibility — *Security OF the Cloud*

AWS protects the infrastructure that runs all AWS services.

AWS is responsible for:

- Physical data centers

- Hardware & networking
- Global infrastructure
- Host operating systems (for managed services)
- Availability Zones & Regions

📌 **Exam phrase:** *"Security of the cloud"* → **AWS**

👤 Customer Responsibility — *Security IN the Cloud*

Customers secure what they put **into** AWS.

Customer is responsible for:

- IAM users, roles, and permissions
- Data encryption
- Operating system (for EC2)
- Network configuration (VPC, security groups)
- Application security
- Patch management (for unmanaged services)

📌 **Exam phrase:** *"Security in the cloud"* → **Customer**

🤝 Shared Responsibilities

Some responsibilities are **shared**, depending on the service:

Shared Area	Who Does What
Patch management	AWS (infra), Customer (OS/apps)

Configuration	AWS provides tools, Customer configures
Compliance	AWS provides compliant services, Customer uses them correctly
Encryption	AWS provides encryption services, Customer enables and manages keys

📌 **Exam trick:** AWS provides the *tools* — **customer must configure them**

🔄 How Responsibility Shifts by Service Type

🖥️ Amazon EC2 (Infrastructure as a Service – IaaS)

More responsibility on the customer

AWS handles:

- Physical servers
- Data center security
- Underlying infrastructure

Customer handles:

- OS updates & patches
- Firewall rules (security groups)
- Applications
- Data encryption
- IAM configuration

📌 **Exam keyword:** *"Customer manages OS"* → EC2

🗄️ Amazon RDS(relational database service) (Platform as a Service – PaaS)

Shared responsibility increases

AWS handles:

- OS & database patching
- Backups
- High availability
- Infrastructure

Customer handles:

- Database configuration
- Access control
- Data security
- Query optimization

📌 **Exam keyword:** *"No database admin"* → RDS

⚡ AWS Lambda (Serverless)

AWS handles almost everything

AWS handles:

- Servers
- OS
- Scaling
- Availability
- Patching

Customer handles:

- Function code
- IAM permissions
- Data security

📌 **Exam keyword:** *"No servers to manage"* → Lambda

📊 Responsibility Comparison Table (Very Exam-Important)

Service	Customer Responsibility Level
Amazon EC2	🔴 High
Amazon RDS	🟠 Medium
AWS Lambda	🟢 Low

👉 **More managed = less customer responsibility**

🎯 Exam Scenarios You MUST Recognize

Scenario 1:

"Who is responsible for patching the operating system on EC2?"
✔ Customer

Scenario 2:

"Who secures physical access to AWS data centers?"
✔ AWS

Scenario 3:

“Who configures IAM policies?”
✔ Customer

Scenario 4:

“Who manages the database engine in Amazon RDS?”
✔ AWS

Scenario 5:

“Who is responsible for application code in Lambda?”
✔ Customer

🧠 Memory Trick (Very Useful)

🟦 AWS = Buildings & Hardware
🟩 Customer = Data & Access
🟨 More managed service → Less customer work

Shifting Responsibilities by Service Type

Responsibilities vary depending on the service model:

Service Type	AWS Role	Customer Role
Amazon EC2 (IaaS)	Secures hypervisor, physical host, networking	Secures OS, applications, IAM, data
Amazon RDS (Managed DB)	Secures DB software, patching, backups infra	Secures schema, queries, IAM, data encryption
AWS Lambda (Serverless)	Secures runtime, scaling, infra	Secures code logic, IAM, data handling

Exam Perspective

- Expect **scenario questions**: “Who is responsible for patching the OS in EC2?” → Customer.
- Watch for **trick shifts**: In RDS, AWS patches DB engine, but customer secures data.
- Remember the **“of vs. in” phrase** — it’s a common exam keyword.
- Be ready to **map services to responsibility boundaries**.

✅ Quick mnemonic:

- **IaaS (EC2)** → Customer does more.
- **PaaS (RDS)** → Split responsibilities.
- **FaaS (Lambda)** → AWS does more.

🔥 EXAM-TRAP MCQs

(AWS Shared Responsibility Model – with full forms)

Q1. Who is responsible for patching the guest operating system on an Amazon EC2 instance?

A. Amazon Web Services
B. Customer
C. AWS Support
D. Shared responsibility

Q2. Which responsibility belongs to Amazon Web Services under the shared responsibility model?

A. Configuring IAM policies
B. Encrypting application data
C. Securing physical data centers
D. Installing application updates

Q3. A company uses Amazon RDS (Relational Database Service). Who is responsible for database engine patching?

A. Customer
B. AWS
C. Third-party vendor
D. Shared responsibility

Q4. Which task is always the customer's responsibility, regardless of the AWS service used?

A. Physical hardware maintenance
B. Data classification and protection
C. Network infrastructure
D. Availability Zone design

Q5. A developer uses AWS Lambda to run code. Which responsibility remains with the customer?

A. Server provisioning
B. Operating system patching
C. Function code security
D. Scaling infrastructure

Q6. Which AWS service places the MOST security responsibility on the customer?

A. AWS Lambda
B. Amazon RDS
C. Amazon EC2
D. Amazon DynamoDB

Q7. Who is responsible for configuring security groups for an Amazon EC2 instance?

A. AWS
B. Customer
C. Shared responsibility
D. AWS Marketplace

Q8. Which statement BEST describes the AWS shared responsibility model?

A. AWS manages all security controls
B. Security responsibilities are divided between AWS and the customer
C. Customers manage physical data centers
D. Security depends on region selection

Q9. A company stores data in Amazon S3 (Simple Storage Service). Who is responsible for configuring bucket permissions?

A. AWS
B. Customer
C. AWS Shield
D. Shared responsibility

Q10. Which service requires the LEAST customer management effort?

A. Amazon EC2 (Elastic Compute Cloud)
B. Amazon RDS (Relational Database Service)
C. AWS Lambda
D. Self-managed database on EC2

✅ Answers (Hidden in exam style 😉)

1️⃣ B
2️⃣ C
3️⃣ B
4️⃣ B
5️⃣ C
6️⃣ C
7️⃣ B

8️⃣ B
9️⃣ B
🔟 C

Task Statement 2.2: Understand AWS Cloud security, governance, and compliance concepts

Knowledge of: • AWS compliance and governance concepts • Benefits of cloud security (for example, encryption) • Where to capture and locate logs that are associated with cloud security Skills in: • Identifying where to find AWS compliance information (for example, AWS Artifact) • Understanding compliance needs among geographic locations or industries (for example, AWS Compliance) • Describing how customers secure resources on AWS (for example, Amazon Inspector, AWS Security Hub, Amazon GuardDuty, AWS Shield) • Identifying different encryption options (for example, encryption in transit, encryption at rest) • Recognizing services that aid in governance and compliance (for example, monitoring with Amazon CloudWatch; auditing with AWS CloudTrail, AWS Audit Manager, and AWS Config; reporting with access reports) • Recognizing compliance requirements that vary among AWS services

1️⃣ AWS Compliance & Governance Concepts

✅ What “Compliance” means in AWS

- **Compliance** = AWS meets global standards, laws, and regulations
- AWS is compliant with standards like:
    - ISO
    - SOC 1, SOC 2, SOC 3
    - PCI-DSS

- HIPAA
- GDPR

👉 **Key idea for exam:**
AWS manages **infrastructure compliance**, customers manage **how they use AWS** (**Shared Responsibility Model**)

🏛️ AWS Governance

Governance = **rules, controls, and visibility** over AWS usage

Includes:

- Monitoring
- Auditing
- Logging
- Policy enforcement

2️⃣ Benefits of Cloud Security (Encryption)

🔒 Encryption

Encryption protects data by converting it into unreadable format.

Two main types (VERY IMPORTANT):

Type	Meaning	Example
Encryption at rest	Data stored on disk	S3, EBS, RDS
Encryption in transit	Data moving over network	HTTPS, TLS

👉 **Exam tip:**
AWS supports encryption **by default** for many services.

3️⃣ Where Logs Are Captured & Stored

📂 Logging = security visibility

Service	What it Logs
AWS CloudTrail	API calls & account activity
Amazon CloudWatch	Metrics, logs, alarms
AWS Config	Resource configuration changes
VPC Flow Logs	Network traffic info

👉 **Exam favorite:**
CloudTrail = WHO did WHAT and WHEN

4️⃣ Where to Find AWS Compliance Information

🗂️ AWS Artifact (EXAM FAVORITE)

- Central portal for **compliance reports**
- Download audit reports (SOC, ISO, PCI)

👉 Question style:

> "Where can customers access AWS compliance reports?"
> ✔️ **AWS Artifact**

5️⃣ Compliance by Geography or Industry

AWS compliance varies by:

- **Region** (data residency laws)

- **Industry** (finance, healthcare, government)

Examples:

- HIPAA → healthcare
- PCI DSS → payment cards
- GDPR → EU data protection

👉 **Key takeaway:**
Customers are responsible for choosing **compliant regions & services**

6️⃣ How Customers Secure AWS Resources

🛡️ Core AWS Security Services (Know what each one does!)

Service	Purpose
Amazon GuardDuty	Threat detection (malicious activity)
Amazon Inspector	Vulnerability scanning
AWS Security Hub	Central security dashboard
AWS Shield	DDoS protection

👉 **Memory trick**:

- **GuardDuty** = *detects threats*
- **Inspector** = *checks vulnerabilities*
- **Security Hub** = *security dashboard*
- **Shield** = *DDoS protection*

7️⃣ Encryption Options

🔐 Encryption Choices on AWS

- **Server-side encryption** (AWS handles keys)
- **Client-side encryption** (customer handles keys)
- **AWS KMS** – key management service

👉 Exam loves:

- Encryption **at rest**
- Encryption **in transit**
- **AWS KMS** for managing keys

8️⃣ Governance, Auditing & Monitoring Services

👀 Monitoring

- **Amazon CloudWatch**
  - Metrics
  - Logs
  - Alarms

🧾 Auditing

Service	Purpose
AWS CloudTrail	API activity
AWS Config	Resource configuration
AWS Audit Manager	Automates audit evidence

📊 Reporting

- **IAM Access Advisor / Access Reports**
    - Shows which permissions are actually used

9️⃣ Compliance Differences Between Services

- **Not all AWS services are compliant with all standards**
- Customers must:
    - Check service compliance
    - Choose correct regions
    - Configure services securely

👉 **AWS provides tools, but customers are responsible for usage**

🧠 EXAM SUMMARY (Memorize This)

- **AWS Artifact** → compliance reports
- **CloudTrail** → API activity logs
- **CloudWatch** → monitoring
- **Config** → configuration tracking
- **GuardDuty** → threat detection
- **Inspector** → vulnerability scanning
- **Shield** → DDoS protection
- **Encryption at rest & in transit** → data protection

==========

🔐 AWS Security, Governance & Compliance — Service Explanations

---

🗂️ AWS Artifact

What it is:
A **self-service portal** for AWS compliance documentation.

What it does:

- Provides access to:
  - SOC reports
  - ISO certifications
  - PCI reports
- Used for **audits and regulatory proof**

Exam takeaway:
👉 *"Where do I download AWS compliance reports?"* → **AWS Artifact**

👀 Amazon CloudWatch

What it is:
AWS's **monitoring and observability service**.

What it monitors:

- Performance metrics (CPU, memory, latency)
- Logs from applications and services
- Alarms for thresholds

Security relevance:

- Detect unusual behavior
- Monitor system health
- Trigger alerts for potential issues

Exam takeaway:
👉 **Monitoring service** (not auditing)

🧾 AWS CloudTrail

What it is:
A **logging and auditing service**.

What it records:

- API calls
- User activity
- Actions taken in your AWS account

Answers questions like:

- Who made this change?
- What resource was accessed?
- When did it happen?

Exam favorite phrase:
👉 *"Who did what and when"*

🧠 AWS Config

What it is:
A **configuration tracking service**.

What it does:

- Records configuration changes of AWS resources
- Checks compliance against rules
- Tracks resource history

Example:

- Detects if an S3 bucket becomes public
- Ensures security groups follow rules

Difference from CloudTrail:

- CloudTrail → *actions*
- Config → *resource configuration state*

🛡️ Amazon GuardDuty

What it is:
An **intelligent threat detection service**.

How it works:

- Uses machine learning
- Analyzes:
    - CloudTrail logs
    - VPC Flow Logs
    - DNS logs

Detects:

- Unauthorized access
- Compromised instances
- Malicious activity

Exam takeaway:
👉 **Detects threats**, does not block them

🔍 Amazon Inspector

What it is:
An **automated vulnerability assessment service**.

What it checks:

- EC2 instances
- Container images
- Lambda functions

Finds:

- Security vulnerabilities
- Missing patches
- Deviations from best practices

Exam takeaway:
👉 **Inspector = vulnerability scanning**

🧩 AWS Security Hub

What it is:
A **central security management dashboard**.

What it does:

- Collects findings from:
  - GuardDuty
  - Inspector
  - AWS Config
- Provides a **single security view**

Why it matters:

- Simplifies security posture management
- Improves visibility

Exam takeaway:
👉 **Security Hub = security dashboard**

🌐 AWS Shield

What it is:
A **DDoS protection service**.

Types:

- **Shield Standard** – automatic, free
- **Shield Advanced** – paid, enhanced protection

Protects against:

- Distributed Denial of Service attacks

Exam takeaway:
👉 **Shield = DDoS protection**

🔑 AWS Key Management Service (AWS KMS)

What it is:
A **managed encryption key service**.

What it does:

- Creates and manages encryption keys
- Integrates with:
    - S3
    - EBS
    - RDS
    - Lambda

Used for:

- Encryption at rest
- Controlling access to encrypted data

Exam takeaway:
👉 **KMS = manage encryption keys**

📊 AWS Audit Manager

What it is:
A **compliance audit automation service**.

What it does:

- Collects audit evidence automatically

- Helps prepare for compliance audits

Used for:

- SOC
- ISO
- Internal audits

Exam takeaway:
👉 Reduces **manual audit effort**

🔍 IAM Access Reports / Access Advisor

What it is:
A **permissions reporting tool**.

What it shows:

- Which permissions are actually used
- Helps identify over-permissioned users

Security benefit:

- Supports least-privilege principle

🌐 VPC Flow Logs

What it is:
A **network traffic logging service**.

What it captures:

- IP traffic information

- Accepted and rejected traffic

Used for:

- Network security analysis
- Troubleshooting

🔐 Encryption Concepts (Tied to Services)

Encryption at Rest

- Protects stored data
- Uses KMS
- Example: S3, EBS, RDS

Encryption in Transit

- Protects data while moving
- Uses TLS/HTTPS

Exam rule:
👉 AWS supports **both types**

🧠 FINAL MEMORY MAP (EXAM GOLD)

Goal	Service
Compliance reports	AWS Artifact
Monitoring	CloudWatch
API auditing	CloudTrail

Config tracking	AWS Config
Threat detection	GuardDuty
Vulnerability scanning	Inspector
Security overview	Security Hub
DDoS protection	Shield
Encryption keys	KMS
Audit automation	Audit Manager

AWS Cloud Practitioner — Security, Governance & Compliance (MCQs)

Question 1

Which AWS service allows customers to **download SOC, ISO, and PCI compliance reports**?

A. AWS Config
B. AWS Artifact
C. AWS CloudTrail
D. AWS Security Hub

Question 2

Which AWS service is primarily used to **record API calls and user activity** in an AWS account?

A. Amazon CloudWatch
B. AWS Config
C. AWS CloudTrail
D. Amazon GuardDuty

Question 3

A company wants to **detect unusual or malicious activity** in their AWS account using machine learning. Which service should they use?

A. AWS Shield
B. Amazon Inspector
C. Amazon GuardDuty
D. AWS CloudTrail

Question 4

Which AWS service helps identify **security vulnerabilities and missing patches** on EC2 instances?

A. AWS Config
B. Amazon Inspector
C. AWS Security Hub
D. Amazon CloudWatch

Question 5

Which AWS service provides a **centralized view of security findings** from multiple AWS services?

A. Amazon GuardDuty
B. AWS CloudTrail
C. AWS Security Hub
D. AWS Audit Manager

Question 6

Which AWS service helps protect applications from **Distributed Denial of Service (DDoS) attacks**?

A. AWS Firewall Manager
B. Amazon GuardDuty
C. AWS Shield
D. Amazon Inspector

Question 7

Which encryption method protects data **while it is being transmitted over a network**?

A. Encryption at rest
B. Server-side encryption
C. Encryption in transit
D. Client-side encryption

Question 8

Which AWS service continuously **tracks configuration changes** and evaluates resources against compliance rules?

A. AWS CloudTrail
B. AWS Config
C. Amazon CloudWatch
D. AWS Artifact

Question 9

Which AWS service is used to **monitor metrics, logs, and set alarms**?

A. AWS CloudTrail
B. Amazon GuardDuty
C. Amazon CloudWatch
D. AWS Audit Manager

Question 10

Who is responsible for choosing the correct **AWS region and services** to meet regulatory compliance requirements?

A. AWS only
B. The customer only
C. AWS and the customer
D. AWS Marketplace vendors

✅ ANSWER KEY — AWS Cloud Practitioner (Task 2.2)

Q1. B — AWS Artifact
→ Used to download SOC, ISO, PCI compliance reports.

Q2. C — AWS CloudTrail
→ Records API calls and user activity ("who did what and when").

Q3. C — Amazon GuardDuty
→ Uses machine learning to detect suspicious or malicious activity.

Q4. B — Amazon Inspector
→ Scans for vulnerabilities and missing patches.

Q5. C — AWS Security Hub
→ Centralized dashboard for security findings.

Q6. C — AWS Shield
→ Protects against DDoS attacks.

Q7. C — Encryption in transit
→ Protects data while moving over a network (TLS/HTTPS).

Q8. B — AWS Config
→ Tracks configuration changes and evaluates compliance.

Q9. C — Amazon CloudWatch
→ Monitors metrics, logs, and alarms.

Q10. C — AWS and the customer
→ Shared Responsibility Model: AWS handles infrastructure, customers handle usage, regions, and configurations.

Task Statement 2.3: Identify AWS access management capabilities.

Knowledge of:
• Identity and access management (for example, AWS Identity and Access Management [IAM])
• Importance of protecting the AWS root user account
• Principle of least privilege

• AWS IAM Identity Center (AWS Single Sign-On)

Skills in:
• Understanding access keys, password policies, and credential storage (for example, AWS Secrets Manager, AWS Systems Manager)
• Identifying authentication methods in AWS (for example, multi-factor authentication [MFA], IAM Identity Center, cross-account IAM roles)
• Defining groups, users, custom policies, and managed policies in compliance with the principle of least privilege
• Identifying tasks that only the account root user can perform
• Understanding which methods can achieve root user protection
• Understanding the types of identity management (for example, federated)

Excellent — this is a **very testable Cloud Practitioner topic**.
I'll give you **clear, detailed, descriptive explanations** of **every AWS service used in Task 2.3**, with **exam language**, **use cases**, and **why AWS offers each service**.

🔑 AWS Access Management — Service Descriptions (Task 2.3)

👤 AWS Identity and Access Management (IAM)

What it is

IAM is AWS's **core access control service**. It allows you to define **who can access AWS resources and what actions they can perform**.

What IAM manages

- Users (people or applications)
- Groups (collections of users)
- Roles (temporary permissions)
- Policies (rules defining access)

Key characteristics

- Global service (not region-specific)
- Integrated with all AWS services
- Supports authentication and authorization

Exam importance

👉 **IAM = access control foundation of AWS**

👑 AWS Root User

What it is

The **root user** is the original account identity created when an AWS account is opened.

Capabilities

- Has **full, unrestricted access**
- Cannot be limited by IAM policies

AWS guidance

- Do not use root for daily tasks
- Protect it with MFA
- Store credentials securely

Exam angle

👉 Root user should be **protected and rarely used**

👥 IAM Users

What they are

IAM users represent **individual identities** for people or applications that need access to AWS.

Access methods

- AWS Management Console (username/password)
- Programmatic access (access keys)

Best practices

- Avoid attaching permissions directly
- Use groups or roles
- Rotate access keys

👥 IAM Groups

What they are

Groups are **collections of IAM users**.

Purpose

- Simplify permission management
- Apply policies to many users at once

Example

- “Admins” group
- “Developers” group

Exam tip

👉 Permissions should be assigned to **groups**, not users

🎭 IAM Roles

What they are

IAM roles provide **temporary security credentials**.

Key features

- No username or password
- Credentials expire automatically

- Trusted entities assume roles

Used by

- AWS services (EC2, Lambda)
- Cross-account access
- Federated users

Exam importance

👉 Roles are **more secure than access keys**

📜 IAM Policies

What they are

Policies are **JSON documents** that define permissions.

What policies specify

- Allowed or denied actions
- Resources affected
- Conditions

Types of policies

- AWS managed policies
- Customer managed policies
- Inline policies

Exam focus

👉 Policies enforce **least privilege**

🔐 IAM Identity Center (AWS Single Sign-On)

What it is

IAM Identity Center provides **centralized identity management** and **single sign-on (SSO)**.

What it allows

- One login for multiple AWS accounts
- Access to business applications
- Federation with corporate directories

Integrations

- Active Directory
- External identity providers

Exam takeaway

👉 IAM Identity Center = **enterprise SSO solution**

🔑 AWS Access Keys

What they are

Access keys enable **programmatic access** to AWS services.

Components

- Access key ID
- Secret access key

Best practices

- Never hardcode
- Rotate regularly
- Do not create for root user

Exam warning

👉 Access keys must be protected

🔐 Multi-Factor Authentication (MFA)

What it is

MFA adds an **extra security layer** by requiring more than one authentication factor.

Factors

- Something you know (password)
- Something you have (MFA device)

Used for

- Root user protection
- IAM users
- Critical operations

Exam favorite

👉 Enable MFA on **root account**

🔒 AWS Secrets Manager

What it is

A **managed secrets storage service**.

Stores

- Database credentials
- API keys
- Tokens

Key features

- Automatic secret rotation
- Encryption at rest
- Tight IAM integration

Exam use case

👉 Prevents hardcoding credentials

⚙️ AWS Systems Manager – Parameter Store

What it is

A **configuration and secrets storage service**.

Stores

- Configuration values
- Encrypted secrets

Differences from Secrets Manager

- Lower cost
- No automatic rotation (by default)

Exam tip

👉 Used for app configuration

🔁 Cross-Account IAM Roles

What they are

Roles that allow **users or services in one AWS account** to access resources in another account.

Security advantage

- No credential sharing
- Temporary access only

Exam scenario

👉 Preferred over access keys for cross-account access

🌐 Federated Identity Management

What it is

Federation allows users to authenticate using **external identity providers**.

How it works

- AWS trusts an external provider
- Users assume IAM roles
- No IAM user required

Used with

- IAM Identity Center
- Corporate directories

Exam focus

👉 Federation = external authentication

🧠 FINAL EXAM MEMORY MAP

Goal	Service
Access control	IAM
Root protection	MFA
Daily access	IAM users
Permission management	Groups
Temporary access	Roles
Enterprise login	IAM Identity Center
Secret storage	Secrets Manager
Config storage	Parameter Store
External identities	Federation

📝 AWS Cloud Practitioner – Task 2.3 (MCQs)

Question 1

Which AWS service is used to **control who can access AWS resources and what actions they can perform**?

A. AWS Organizations
B. AWS Identity and Access Management (IAM)
C. AWS Shield
D. Amazon CloudWatch

Question 2

Which of the following is a **best practice** for protecting the AWS root user account?

A. Use the root user for daily administrative tasks
B. Attach IAM policies to the root user
C. Enable multi-factor authentication (MFA)
D. Create access keys for the root user

Question 3

Which principle states that users should be granted **only the permissions required** to perform their job functions?

A. Shared responsibility
B. Defense in depth
C. Least privilege
D. High availability

Question 4

Which AWS identity type provides **temporary security credentials** and is commonly used by AWS services and for cross-account access?

A. IAM user
B. IAM group
C. IAM role
D. Root user

Question 5

Which AWS service enables **single sign-on (SSO)** access to multiple AWS accounts and applications?

A. AWS IAM
B. AWS Secrets Manager
C. IAM Identity Center
D. AWS Directory Service

Question 6

Which AWS feature adds an **extra layer of protection** by requiring users to provide more than one authentication factor?

A. Access keys
B. IAM policies
C. Multi-factor authentication (MFA)
D. Security groups

Question 7

Which AWS service is best suited for **securely storing database credentials and API keys with automatic rotation**?

A. AWS Systems Manager Parameter Store
B. AWS IAM
C. AWS Secrets Manager
D. Amazon S3

Question 8

Which IAM entity is primarily used to **assign permissions to multiple users at once**?

A. IAM role
B. IAM group
C. IAM policy
D. Root user

Question 9

Which type of identity management allows users to **authenticate using an external identity provider** such as a corporate directory?

A. Local IAM authentication
B. Root user authentication
C. Federated identity
D. Access key authentication

Question 10

Which task can **only** be performed by the AWS account root user?

A. Launch an EC2 instance
B. Attach a managed policy to an IAM user
C. Close the AWS account
D. Create an IAM role

✅ Answer Key

1. **B — AWS Identity and Access Management (IAM)**
2. **C — Enable multi-factor authentication (MFA)**
3. **C — Least privilege**
4. **C — IAM role**
5. **C — IAM Identity Center**
6. **C — Multi-factor authentication (MFA)**
7. **C — AWS Secrets Manager**
8. **B — IAM group**
9. **C — Federated identity**
10. **C — Close the AWS account**

🧠 Exam Tip Recap

- **IAM** controls access
- **Root user** → protect with MFA, use rarely
- **Roles** → temporary, secure access

- **IAM Identity Center** → SSO & federation
- **Secrets Manager** → secret storage + rotation
- **Least privilege** → minimum permissions

Task Statement 2.4: Identify components and resources for security

Knowledge of:
• Security capabilities that AWS provides
• Security-related documentation that AWS provides
Skills in:
• Describing AWS security features and services (for example, security groups, network ACLs, AWS WAF)
• Understanding that third-party security products are available from AWS Marketplace
• Identifying where AWS security information is available (for example, AWS Knowledge Center, AWS Security Center, AWS Security Blog)
• Understanding the use of AWS services for identifying security issues (for example, AWS Trusted Advisor)

Excellent — **Task 2.4 is very exam-heavy** and full of **"identify the right service" traps**.
I'll explain it **clearly, descriptively, and in exam language**, with **ALL AWS service full forms included**.

🔐 Domain 2: Security & Compliance

Task 2.4: Identify Components and Resources for Security

🧠 SUMMARY NOTES (Quick Exam View)

- AWS provides **built-in security services** for network, application, data, and account protection
- Security is implemented using **preventive, detective, and advisory controls**
- AWS publishes **official security documentation** and blogs
- Third-party security tools are available via **AWS Marketplace**
- AWS offers services to **detect misconfigurations and risks automatically**

🔐 AWS SECURITY CAPABILITIES (WHAT AWS PROVIDES)

AWS security services fall into **4 major categories**:

1️⃣ Network Security
2️⃣ Application Security
3️⃣ Threat Detection
4️⃣ Advisory & Monitoring

🌐 NETWORK SECURITY SERVICES

🔒 Security Groups

What it is:
A **virtual firewall** for Amazon EC2 (Elastic Compute Cloud) instances.

Key points:

- Stateful (return traffic automatically allowed)
- Control inbound & outbound traffic
- Attached at instance level

📌 **Exam keywords:**
“Instance-level firewall”, “stateful”

🧱 Network ACLs (Access Control Lists)

What it is:
A **subnet-level firewall** for Amazon VPC (Virtual Private Cloud).

Key points:

- Stateless (must allow inbound & outbound separately)
- Applied at subnet level
- Evaluated in rule number order

📌 **Exam keywords:**
"Subnet-level", "stateless"

🛡️ APPLICATION SECURITY

🧯 AWS WAF

Full Form: AWS **Web Application Firewall**

What it does:

- Protects web applications from:
  - SQL injection
  - Cross-site scripting (XSS)
- Works with:
  - Amazon CloudFront
  - Application Load Balancer (ALB)
  - Amazon API Gateway

📌 **Exam keywords:**
"Web attacks", "Layer 7 protection"

🚨 THREAT DETECTION SERVICES

👁️ AWS GuardDuty

Full Form: AWS **GuardDuty**

What it does:

- Continuous threat detection
- Uses:
  - Machine learning
  - CloudTrail logs

    - VPC Flow Logs
    - DNS logs

📌 **Exam keywords:**
"Threat detection", "suspicious activity"

🧪 Amazon Inspector

Full Form: Amazon **Inspector**

What it does:

- Scans workloads for:
    - Vulnerabilities
    - Exposures
- Focused on EC2 & container images

📌 **Exam keywords:**
"Vulnerability assessment"

📊 ADVISORY & MONITORING

📘 AWS Trusted Advisor

Full Form: AWS **Trusted Advisor**

What it does:

- Checks AWS environment against best practices
- 5 categories:
    - Cost optimization
    - Performance
    - Security
    - Fault tolerance
    - Service limits

📌 **Exam keywords:**
"Best practice recommendations"

🛒 THIRD-PARTY SECURITY TOOLS

🏪 AWS Marketplace

What it is:
A digital catalog for **third-party software**, including security tools.

Examples:

- Firewalls
- Antivirus
- SIEM tools

📌 **Exam keyword:**
“Third-party security solutions”

📚 AWS SECURITY DOCUMENTATION & INFORMATION SOURCES

🔎 AWS Knowledge Center

- FAQs
- How-to guides
- Troubleshooting articles

🛡️ AWS Security Center

- Central hub for AWS security services
- Compliance & risk information

📰 AWS Security Blog

- Updates on:
    - New security features
    - Best practices
    - Threat intelligence

📌 **Exam tip:**
If question asks **“Where to learn security best practices?”** → Blog / Knowledge Center

---

🧠 EXAM COMPARISON TABLE

Service	Full Form	Purpose
Security Groups	—	Instance firewall
Network ACLs	Access Control List	Subnet firewall
AWS WAF	Web Application Firewall	Web attack protection
AWS GuardDuty	—	Threat detection
Amazon Inspector	—	Vulnerability scanning
AWS Trusted Advisor	—	Best practice checks

🧪 MINI MOCK TEST (EXAM STYLE)

Q1. Which AWS service protects web applications from SQL injection attacks?

A. AWS Shield
B. AWS WAF
C. Amazon GuardDuty
D. Network ACL

Q2. Which firewall is stateful?

A. Network ACL
B. AWS WAF
C. Security Group
D. AWS Shield

Q3. A company wants best-practice security recommendations. Which service should they use?

A. AWS GuardDuty
B. Amazon Inspector
C. AWS Trusted Advisor
D. AWS Security Hub

Q4. Where can customers find official AWS security best practices?

A. AWS Marketplace
B. AWS Knowledge Center
C. Amazon EC2 Console
D. AWS Lambda

Q5. Which service detects suspicious API activity?

A. Amazon Inspector
B. AWS GuardDuty
C. AWS WAF
D. Network ACL

Q6. Which AWS resource controls traffic at the subnet level?

A. Security Group
B. AWS WAF
C. Network ACL
D. AWS Shield

Q7. Which service scans EC2 instances for vulnerabilities?

A. AWS Trusted Advisor
B. Amazon Inspector
C. AWS GuardDuty
D. AWS WAF

Q8. Where can third-party security tools be purchased?

A. AWS Security Center
B. AWS Knowledge Center
C. AWS Marketplace
D. AWS Shield

Q9. Which service provides continuous threat detection using machine learning?

A. Amazon Inspector
B. AWS Trusted Advisor
C. AWS GuardDuty
D. AWS WAF

Q10. Which AWS service is best for identifying unused security groups?

A. Amazon Inspector
B. AWS Trusted Advisor
C. AWS WAF
D. AWS GuardDuty

✅ ANSWERS

1️⃣ B
2️⃣ C
3️⃣ C
4️⃣ B
5️⃣ B
6️⃣ C
7️⃣ B
8️⃣ C
9️⃣ C
🔟 B

🎯 FINAL EXAM MEMORY RULES

- **Firewall?** → Security Group / Network ACL
- **Web attacks?** → AWS WAF
- **Threat detection?** → AWS GuardDuty
- **Vulnerabilities?** → Amazon Inspector
- **Best practices?** → AWS Trusted Advisor
- **Third-party tools?** → AWS Marketplace